Supplier and Vendor Management Policy

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review

Purpose

This policy ensures that all third-party vendors, suppliers, and service providers engaged by Stark Industries Inc. are evaluated, monitored, and governed in a manner that protects the confidentiality, integrity, and availability of information systems and services. This policy is aligned with ISO/IEC 27001:2022 (A.5.19 – A.5.22).

Scope

Applies to all suppliers and vendors providing products or services that could impact the ISMS, including cloud services (e.g. AWS, GitHub), SaaS tools, development partners, managed service providers, and consultants.

Policy Objectives

- Ensure suppliers meet security and compliance requirements.
- Reduce third-party risk through due diligence and oversight.
- Protect Stark Industries' systems, data, and reputation.

Supplier Lifecycle Requirements

1) Identification & Classification (A.5.19)
    - Suppliers are categorised based on risk:
        - Critical: Have access to production systems or sensitive data (e.g. AWS)
        - Operational: Support internal tools or non-sensitive workflows (e.g. Jira)
        - Low-Risk: No system access, non-technical vendors (e.g. office supplies)
2) Risk Assessment (A.5.20)
    - All critical and operational suppliers must undergo an initial risk assessment prior to onboarding.
    - Assessment includes:
        - Security certifications (e.g. ISO 27001, SOC 2)
        - Data handling practices
        - SLAs and availability
        - Legal and compliance checks (e.g. GDPR relevance)
3) Contractual Obligations (A.5.21)
    - All vendor agreements must include:
        - Confidentiality and data protection clauses
        - Breach notification requirements
        - Right to audit or request evidence of security controls

    - Service level expectations (availability, support, patching)

Monitoring and Review (A.5.22)

- Critical vendors are reviewed at least annually.
- Reviews may include:
    - Updated security reports or certifications
    - Performance and SLA reviews
    - Breach history or incident disclosures

Offboarding and Exit Strategy

- Upon contract termination:
    - All access to Stark Industries systems must be revoked
    - Data must be securely returned or destroyed
    - Final audit or verification may be required

Roles and Responsibilities

Role	Responsibilities
Procurement / Legal	Ensure contracts include required clauses
Information Security Manager	Classify vendors, review risks, support audits
System Owners	Request vendor onboarding, monitor performance

Exceptions

- Exceptions must be:
    - Documented
    - Approved by the Information Security Manager
    - Mitigated with alternative controls where feasible

Policy Review

- This policy is reviewed **annually** or upon significant change to the environment or regulatory requirements.